

University of Victoria

SENG 426 - B01

Lab Project 2

June 7, 2026

Aidan Richards - V00990088

MacKenzie Larsen - V00943994

Manraj Minhas - V00998047

Grygorii Karachevtsev - V00983328

Features

Feature: Account Management

Priority: High

Story Points: 5

Description: As an Admin, I want to be able to view the active roles and their permissions on the website when the Admin selects the "Roles and Permissions" tab. They should be able to see the roles with their permissions and display name

User Story: Current Roles and Permissions

Given the Admin is on the Roles and Permissions panel

They should be able to see the current roles with their allocated permissions

And they should be identifiable through a display name

Feature: Resources Management

Priority: High

Story Points: 8

Description: As an Admin, I want to upload resource files up to 50 MB so that they are available in the system for authorized users.

User Story: Successful file upload

Given the Admin is on the "Resources Upload" page

When the Admin clicks "Select File" and chooses a valid file under 50 MB

Then the system should upload the file successfully

And the file should appear in the resources list

And a success notification should be displayed

Feature: Resource Management

Priority: High

Story Points: 5

Description: As an Admin, I want to be able to see the resources uploaded to the "Resources" tab.

User Story: File upload

Given the Admin is on the "Resources Upload" page

When the Admin clicks "Select File"

They should be able to select a file for upload

And successfully upload those files

Then I should be able to see the files uploaded on the "Resources" tab

Feature: Role-Based Access Control (RBAC)

Priority: High

Story Points: 5

Description: As an Employee, I want to access the Resources tab so that I can view company files, but not administrative panels.

User Story: Employee accesses authorized tabs

Given the user is logged in with the "Employee" role

When they view the navigation bar

Then they should see the standard links plus the "Resources" tab

And they should NOT see the Admin Panel tab

And they should be denied access if they try to manually navigate to /AdminPanel

Feature: Account Management

Priority: Medium

Story Points: 3

Description: As an Admin, I want to review and activate newly registered accounts so that valid users and employees can access the Vega App.

User Story: Activating a pending account

Given a new user has registered and is listed in the "New Accounts" panel

When the Admin clicks the "Activate" button next to the account

Then the account status should change to "active"

And the account should be moved to the appropriate role-based tab

Feature: Account Management

Priority: Medium

Story Points: 2

Description: As an Admin, I want to view accounts filtered by their assigned roles so that I can easily manage Staff and Regular Users separately.

User Story: Viewing role-specific account lists

Given the Admin is on the Accounts panel

When the Admin selects the "Staff Accounts" tab

Then only accounts with the "Employee" or "Admin" role should be displayed

Feature: Account Management

Priority: High

Story Points: 3

Description: As a new user, I want to be prompted to create a strong password so that my account remains secure.

User Story: Creating an account with a weak password

Given that a user is on the account creation page

When the user types a new password that is not complex enough

And attempts to submit the form

Then the system should reject the password
And prompt the user to make it stronger

Feature: Account Management

Priority: High

Story Points: 4

Description: As an Admin, I want to view all active roles and their permissions so that I can verify access levels across the application.

User Story: Viewing current Roles and Permissions

Given the Admin is on the "Roles & Permissions" panel

When the Admin views the roles list

Then they should be able to see all current roles

And each role should have its allocated permissions displayed

And each role should be identifiable through a display name

Feature: Role-Based Access Control (RBAC)

Priority: High

Story Points: 8

Description: As a Standard User

I want to only access public and personal features

User Story: User accesses authorized tabs

Given the user is logged in with the "User" role

When they view the navigation bar

Then they should only see links for Platform Information, News & Events, Leadership, Contact us, Defense Dashboard, and Download Defense App

And they should NOT see the Resources or Admin Panel tabs

And they should be denied access if they try to manually navigate to /AdminPanel or /resources

Feature: Role-Based Access Control (RBAC)

Priority: High

Story Points: 8

Description: As an Employee

I want to access the Resources tab

So that I can view company files, but not administrative panels

User Story: Employee accesses authorized tabs

Given the user is logged in with the "Employee" role

When they view the navigation bar

Then they should see the standard links plus the "Resources" tab

And they should NOT see the Admin Panel tab

And they should be denied access if they try to manually navigate to /AdminPanel

Feature: Defense App Monitoring

Priority: Medium

Story Points: 5

Description: As a registered user

I want to view the Defense Dashboard

So that I can monitor the live defense metrics and system status

User Story: Accessing the Defense Dashboard

Given the user is logged into their account

When they navigate to the "Defense Dashboard" tab

Then the system should display the live telemetry and monitoring data

And the data should update in real-time without crashing

Feature: Defense App Monitoring

Priority: Medium

Story Points: 8

Description: As a registered user

I want to be able to download the Defense App executable

So that I can install it on my local machine

User Story: Downloading the client

Given the user is logged into their account

When they navigate to the "Download Defense App" tab

And click the download button

Then the browser should successfully download the application file

Feature: Public Information

Priority: Medium

Story Points: 3

Description: As a user

I want to view the Platform Information, Leadership, and News pages

So that I can stay informed about Vega Absolute's updates

User Story: Navigating public pages

Given the user is on the web portal

When they click on the News & Events or Leadership tabs

Then the system should load the respective content articles and team profiles

courses / 2026051 / SENG426 / assignments / aidanrichards / SENG426_GP15 / Issue Boards

Development ▾ Label = type:user-story X

Open ▾ 12 28 +

View Existing Resources
priority 2 - High type user-story
#22 To do

Roles and Permissions
priority 2 - High type user-story
#21 To do

Employee Access Restrictions
priority 2 - High type user-story
#18 3 To do

Standard User Access Restrictions
priority 2 - High type user-story
#17 3 To do

Users can view company information and news
priority 4 - Low type user-story
#13 1 To do

Users can download the Defense App client
priority 3 - Medium type user-story
#12 2 To do

Closed ▾ 0 0 0 + New list

courses / 2026051 / SENG426 / assignments / aidanrichards / SENG426_GP15 / Issue Boards

Development ▾ Label = type:bug X

Open ▾ 7 18 +

Public registration can request ADMIN role
priority 3 - Medium severity 2 - High type bug
#23 To do

BUG: Standard Users can bypass UI to access Defense Dashboard via URL
priority 1 - Highest severity 1 - Critical type bug
#24 To do

BUG: Standard Users can bypass UI to access Employee Resources via URL
priority 1 - Highest severity 2 - High type bug
#20 5 To do

BUG: Standard Users and Employees can bypass UI to access Admin Panel via URL
priority 1 - Highest severity 1 - Critical type bug
#19 5 To do

User Login
priority 1 - Highest severity 1 - Critical type bug
#15 To do

BUG: Defense App websocket connection blocked by segmented network
priority 1 - Highest severity 1 - Critical type bug
#14 5 To do

Closed ▾ 0 0 0 + New list

User Login

Edit

Open Issue created 1 hour ago by Grygorii Karachevtsev

Summary

The login endpoint builds a native SQL query that concatenates user-controlled email and password values. Comparisons for credentials are done against plaintext password values, instead of using a configured password encoder.

Reproduction Steps

1. Send a login request
2. Use a fake password, for example: "fakeemail@vega.com"
3. Use an SQL-injection-style password such as: `x' OR '1' = '1`
4. Observe the API response

Expected Behavior

Ideally, the system should reject the login request that contains invalid credentials. Stored passwords should be hashed and verified through a password encoder.

Actual Behavior

The request returned HTTP 200 and an access token for "fakeemail@vega.com" with role "EMPLOYEE".

Impact

An attacker may bypass authentication and obtain a valid user session. Plaintext passwords also expose sensitive account information in case the database or source/configuration are leaked.

Edited 1 hour ago by Grygorii Karachevtsev



0



0



Status

Edit

To do

Assignees

Edit

None - assign yourself

Labels

Edit

priority 1 - Highestseverity 1 - Criticaltype bug

Parent

Edit

None

Weight

Edit

None

Milestone

Edit

None

Iteration

Edit

None

Dates

Edit

Start: None

Due: None

Health status

Edit

None

Time tracking

+

Admin can upload resource files

Edit  

 Open  Issue created 1 hour ago by **Manraj Minhas**

Feature: Resources Management As an Admin I want to upload resource files up to 50 MB So that they are available in the system for authorized users

Scenario: Successful file upload Given the Admin is on the "Resources Upload" page When the Admin clicks "Select File" and chooses a valid file under 50 MB Then the system should upload the file successfully And the file should appear in the resources list And a success notification should be displayed

Edited 1 hour ago by **Manraj Minhas**

 0  0 

 Add design  Create merge request 

Child items 0  + | ^

No child items are currently assigned. Use child items to break down work into smaller parts.

Linked items 2  + | ^

Related to

 View Existing Resources

#22

priority 2 - High

type user-story

 To do 

 Feature: Resource Management

#7

type feature

 To do 

Status	Edit
 To do	
Assignees	Edit
None - assign yourself	
Labels	Edit
priority 2 - High type user-story	
Parent	Edit
None	
Weight	Edit
5	
Milestone	Edit
None	
Iteration	Edit
None	
Dates	Edit
Start: None	
Due: None	
Health status	Edit
None	
Time tracking	+

Story Points vs. Hours

Story points and Hours are both estimation methods commonly used in software development environments in order to schedule and prioritize tasks. Story points are a relative estimation method that is extensively used in Agile team development environments. It is used to estimate the overall effort necessary to complete a user story or a backlog item. Story points do not represent time, instead, they serve as indicators that consider the amount of work that is necessary, the complexity of the task, as well as the risk and uncertainty that is involved.

Hours, on the other hand, are a time based estimation method that estimates how much real working time is necessary to complete a task. While concrete, hour estimates could be misleading as different developers may take different amounts of time to complete the same task, depending on factors such as experience, familiarity with the codebase, interruptions, and unexpected technical problems.

Story points are useful because they encourage relative comparison between backlog items. It allows the team to consider a multitude of factors, instead of having to figure out and argue over the exact amount of time needed. They are also helpful for sprint planning, since over time, teams can learn their average pace and more accurately forecast how much work they can complete. However, they could be confusing for people outside the team since story points do not translate into any tangible hours or dates. Hours are useful due to their simplicity. They are easy to communicate, familiar to most, and are conceptually simple. They are an appropriate method for small, clearly understood tasks, especially if other elements of the task, such as the user story, have already been broken down into implementation steps. However, this simplicity is its biggest shortfall, as hours can create a false sense of precision. This could lead to overcommitments and, in some cases, is ill-suited for handling uncertainty. Especially if the team is working on bugs, security issues, or unfamiliar code.

Ultimately, considering the bugs, security issues, and new features that need fixes or implementation on a code base that is relatively new to the team, Story Points were chosen as the main estimation method. Such a method neatly fits with Gitlab's issue board workflow, which is focused on bugs, features, and user stories.